HealNSight Telemedicine Bangladesh

Secure E-Prescription System: Master Implementation Plan & Architecture

AES-256-GCM Envelope Encryption * Hyperledger Fabric Blockchain * Google Authenticator TOTP

Project: Telemedicine Bangladesh / HealNSight Platform

Security Baseline: AES-256-GCM Envelope Encryption (Cloud KMS Wrapped) + Hyperledger Fabric Blockchain Hash Anchoring + Server-Enforced Consultation Grants + Google Authenticator (RFC 6238 TOTP) Digital Signing + Automatic Threat Lockdown & Dual-Mode Recovery

Core Clinical Invariant: Doctors formulate prescriptions during video/audio consultations; upon approval, doctor consultation grants are immediately and irreversibly revoked. Finalized decrypted PDF documents can only be retrieved by the authenticated patient.

1. System Architecture & Logical Topology

```
flowchart TD
    subgraph Doctor_Workstation ["Doctor Workstation (Port 3000)"]
        D_UI["In-Call / Full-Screen Rx Portal"]
        D_MFA["Google Authenticator (RFC 6238 TOTP)"]
        D_Draft["In-Memory Draft Store (Zero RAM Bleed)"]
    end

    subgraph API_Gateway ["Secure E-Prescription Gateway (Port 5002)"]
        AUTH_GUARD["Consultation Access Guard\n(canViewPatient / canApprove)"]
        CRYPTO_ENGINE["AES-256-GCM Engine\n(Unique 256-bit DEK + KMS Wrap)"]
        LOCKDOWN_SVC["Threat Lockdown Engine\n(Burst Detection & IP Quarantine)"]
        TOTP_SVC["RFC 6238 TOTP Engine\n(Replay Protection & Drift Window)"]
        JOB_DISPATCHER["BullMQ Async Dispatcher\n(Background Encryption Queue)"]
    end

    subgraph Core_Database ["Relational Storage (SQLite / PostgreSQL)"]
        DB_USERS[("Users & BMDC Profiles")]
        DB_GRANTS[("Consultation Grants (Time-Bounded)")]
        DB_RX[("Immutable Prescriptions")]
        DB_FILES[("Encrypted Ciphertext & KMS Tags")]
        DB_AUDIT[("Security Audit Logs & Locks")]
    end

    subgraph Blockchain_Ledger ["Hyperledger Fabric Network"]
CHAINCODE["prescription_integrity Chaincode\nregisterPrescriptionHash(docId, sha256)"]
        LEDGER[("Immutable Merkle Ledger\n(Zero PHI Stored)")]
    end

    subgraph Patient_Vault ["Patient Workstation (Port 3000 / 8000)"]
        P_VAULT["Encrypted Patient Prescription Vault"]
        P_RECOVERY["Dual-Mode Recovery Modal\n(Google 2FA / 5-min OTP)"]
        P_STREAM["Zero-Knowledge Decrypted Stream"]
    end

    D_UI -->|1. Formulate Regimen| D_Draft
    D_Draft -->|2. Sign with 6-Digit TOTP| D_MFA
    D_MFA -->|3. POST /api/prescriptions/approve| AUTH_GUARD
    AUTH_GUARD -->|4. Validate Doctor BMDC & Active Grant| DB_GRANTS
    AUTH_GUARD -->|5. Revoke Doctor Grant Immediately| DB_GRANTS
    AUTH_GUARD -->|6. Dispatch PDF & Crypto Task| JOB_DISPATCHER
    JOB_DISPATCHER -->|7. Envelope Encryption| CRYPTO_ENGINE
    CRYPTO_ENGINE -->|8. Store Ciphertext & AuthTag| DB_FILES
    CRYPTO_ENGINE -->|9. Anchor SHA-256 Digest| CHAINCODE
    CHAINCODE -->|10. Commit Tx| LEDGER
    P_VAULT -->|11. GET /api/patient/prescriptions/:id/download| LOCKDOWN_SVC
```

```
    LOCKDOWN_SVC -->|12. Compare File Hash vs Blockchain| CHAINCODE
    LOCKDOWN_SVC -->|13. Stream Decrypted %PDF Bytes| P_STREAM
```

2. Multi-Layer Security Architecture

Layer 1: AES-256-GCM Envelope Encryption & Key Management

* Unique DEK per Document: Each generated prescription generates a fresh, cryptographically secure 256-bit Data Encryption Key (randomBytes(32)) and a 96-bit initialization vector (randomBytes(12)).
* Galois/Counter Mode (GCM): Provides authenticated encryption. Modifying a single byte of ciphertext causes immediate authentication tag verification failure (ERR_CRYPTO_OPERATION_FAILED).
* Cloud KMS Key Wrapping: DEKs are never saved in plaintext in the database or logs. They are encrypted using the Master Key Encryption Key (KEK) via envelope encryption (wrappedKey = AES-256-CBC(DEK, KEK)).

* Source Module:
[encryption.service.ts](file:///Users/mdniloy/Downloads/telehealth%20bangladesh/telemedicine/backend/src/modules/security/encryptio

Layer 2: Server-Enforced Consultation Grants & Strict Access Boundary

* Time-Bounded Authorization: Doctors obtain temporary, scoped access to patient vitals, allergies, and history through a database entity: ConsultationGrant.
* Immediate Grant Revocation: The exact instant a doctor clicks *Approve & Sign*, the server commits the approved prescription, permanently sets revokedAt = new Date(), and terminates all doctor read/write access.
* Strict Patient-Only Delivery: Finalized prescriptions can only be downloaded by the document's authenticated patient (X-Patient-ID matching prescription.patientId). Doctors, pharmacists, and unauthorized peers receive 403 Forbidden.
* Source Module:
[consultation-access.service.ts](file:///Users/mdniloy/Downloads/telehealth%20bangladesh/telemedicine/backend/src/modules/consulta
&
[prescription-secure.service.ts](file:///Users/mdniloy/Downloads/telehealth%20bangladesh/telemedicine/backend/src/modules/prescrip

Layer 3: Hyperledger Fabric Document Integrity & Blockchain Anchoring

* Zero Protected Health Information (PHI) On-Chain: The blockchain stores strictly: (documentId, version, sha256Hash, timestamp, txId). No patient names, symptoms, medications, or doctor notes ever touch the ledger.
* Pre-Delivery Integrity Re-Computation: Before decrypting a PDF for patient delivery, the backend computes the SHA-256 digest of the ciphertext on disk and compares it to the blockchain ledger.
* Forensic Quarantine: If a mismatch is detected, the document transitions to QUARANTINED. All downloads are aborted, an administrative alert is flagged, and OTP/TOTP unlocking is strictly prohibited.
* Source Modules:
[prescription_integrity.js](file:///Users/mdniloy/Downloads/telehealth%20bangladesh/telemedicine/blockchain/chaincode/prescription_in
&
[blockchain.service.ts](file:///Users/mdniloy/Downloads/telehealth%20bangladesh/telemedicine/backend/src/modules/blockchain/block

Layer 4: Google Authenticator (RFC 6238 TOTP) Digital Signatures & Threat Recovery

* RFC 6238 TOTP Engine: Implements HMAC-SHA1 rotating 6-digit tokens across 30-second windows with a +/-1 step drift allowance.
* Two-Factor Digital Signature: Doctors cannot finalize prescriptions using passwords or checkboxes alone. Approval requires entering the active 6-digit TOTP code paired with their BMDC profile.
* Replay Attack Defense: Tracked tokens prevent reuse of the same 6-digit code within the active time-step.
* 8 Emergency Backup Codes: Users receive 8 single-use cryptographically hashed emergency codes (TB-XXXX-XXXX) for account recovery if their authenticator device is lost.
* Source Module:
[totp.service.ts](file:///Users/mdniloy/Downloads/telehealth%20bangladesh/telemedicine/backend/src/modules/auth/totp.service.ts)

3. Threat Detection, Automated Lockdown & Dual-Mode Recovery

Automated Lockdown Triggers

1. Brute-Force Download Burst: Exceeding 5 failed download or access requests within a 60-second window.
2. Revoked Session Re-Use: A doctor attempting to query patient records after ConsultationGrant expiration.
3. Identity Spoofing: A patient requesting download access for a document belonging to another patient ID.
4. Integrity Violation: Ciphertext digest mismatch against the Hyperledger Fabric ledger (triggers permanent forensic quarantine).

Dual-Mode Identity Recovery

When an access lock is recoverable (securityStatus === 'LOCKED'), the patient can verify their identity using two distinct channels:

* Mode A: Google Authenticator (Instant TOTP): User enters the active 6-digit code from Google Authenticator. Verified in-process with zero network latency.
* Mode B: Single-Use OTP (Email / SMS Fallback): Dispatches a 6-digit cryptographic challenge with a strict 5-minute time-to-live (TTL), single-use invalidation, and a maximum of 3 failed attempts.
* Source Module: [security-lockdown.service.ts](file:///Users/mdniloy/Downloads/telehealth%20bangladesh/telemedicine/backend/src/modules/security/s

4. Database Schema & State Machine

10 Core Entities

Entity	Purpose
User	Patient and Doctor accounts with role-based access control, BMDC registration, and MFA secret storage
Consultation	Video/audio consultation session lifecycle (SCHEDULED, ACTIVE, COMPLETED, CANCELLED)
ConsultationGrant	Time-bounded doctor access token linked to a specific patient and consultation (expiresAt, revokedAt)
Prescription	Approved clinical prescription version (DRAFT, APPROVED, GENERATING, READY, LOCKED)
PrescriptionItem	Clinical regimen items (medication name, dosage, frequency 1+0+1, duration, instructions)
PrescriptionFile	Private encrypted document reference (storage path, wrapped DEK, IV, auth tag, SHA-256 hash)
SecurityEvent	Audit trail recording suspicious bursts, failed auth attempts, locks, and IP addresses
DocumentLock	Active security locks with reason, locked timestamp, and forensic hold status
OtpChallenge	6-digit challenge storage with bcrypt hash, expiry timestamp, attempts count, and consumed flag

AuditLog	Immutable system-wide access logs for compliance and regulatory reporting

Prescription Lifecycle State Machine

```
[ DRAFT ] ??(Doctor Approval + Google 2FA)??> [ APPROVED ]
                                                ?
                                        (Grant Revoked Post-Approval)
                                                ?
                                                ?
                                          [ GENERATING ]
                                                ?
                                         (Puppeteer + AES-256 + Fabric)
                                                ?
                                                ?
                                             [ READY ]
                                              ?     ?
                                (Suspicious Burst) ?     ? (Patient 2FA / OTP Recovery)
                                              ?     ?
                                           [ LOCKED ]
                                              ?
                                (Hash Mismatch)    ?
                                                   ?
                                        [ QUARANTINED ] (Forensic Hold -- OTP Blocked)
```

* Prisma Definition: [schema.prisma](file:///Users/mdniloy/Downloads/telehealth%20bangladesh/telemedicine/backend/prisma/schema.prisma)
* SQLite Persistence Store: [sqlite-store.ts](file:///Users/mdniloy/Downloads/telehealth%20bangladesh/telemedicine/backend/src/db/sqlite-store.ts) & [prisma-adapter.ts](file:///Users/mdniloy/Downloads/telehealth%20bangladesh/telemedicine/backend/src/db/prisma-adapter.ts)

5. Backend REST API Endpoints (Gateway Port 5002)

Method	Endpoint	Authorization	Description
GET	/health	Public	System status, cryptographic engine status, and Fabric ledger connectivity
POST	/api/auth/mfa/setup	Bearer Token	Generates RFC 6238 Base32 secret, QR code data URL, and 8 recovery codes
POST	/api/auth/mfa/verify	Bearer Token	Validates 6-digit code and activates two-factor authentication on account
GET	/api/consultations/:id/grant-status	Doctor / Patient	Validates active consultation grant and remaining grant time-to-live
POST	/api/prescriptions/approve	Doctor + 2FA	Verifies grant, validates doctor TOTP, creates immutable prescription, and revokes grant

GET	/api/prescriptions/patient/list	Patient	Lists all verified encrypted prescriptions in patient vault with blockchain proof pills
GET	/api/patient/prescriptions/:id/download	Patient Only	Recomputes SHA-256 hash against Fabric, unwraps DEK via KMS, and streams decrypted %PDF
POST	/api/security/prescriptions/:id/request-otp	Patient	Dispatches 5-minute single-use OTP challenge to registered email/phone
POST	/api/security/prescriptions/:id/verify-otp	Patient	Validates 6-digit OTP challenge and restores ACTIVE status on recoverable locks
POST	/api/security/prescriptions/:id/verify-totp	Patient	Validates Google Authenticator TOTP token and unlocks prescription access

* Gateway Entrypoint: [index.ts](file:///Users/mdniloy/Downloads/telehealth%20bangladesh/telemedicine/backend/src/index.ts)

6. Frontend Portals & Consultation Workspace Layouts

The Three-Mode Doctor Consultation Workspace

Implemented natively inside [ClinicalRoom.jsx](file:///Users/mdniloy/Downloads/telehealth%20bangladesh/telehealth-bangladesh/frontend-src/src/components/ClinicalR and [ConsultationRoom.tsx](file:///Users/mdniloy/Downloads/telehealth%20bangladesh/telemedicine/frontend/src/components/consultation/Con

```
+-------------------------------------------------------------------------------------------+
| TOP WORKSPACE BAR: Patient: Niloy Hasan (Session #19) | Grant: ACTIVE (58:12) | Exit Room
|
| Workspace Mode Switcher: [ ? Video + E-Prescription ] [ ? Audio + E-Prescription ] [ ?
Full Screen ]|
+---------------------------------+---------------------------------------------------------+
| | SECURE DIGITAL E-PRESCRIPTION PORTAL (Embedded / Full) |
| LIVE PEER VIDEO STREAM | +----------------------+---------------------------------+ |
| (with Camera Ready Preview & | | CLINICAL SAFETY | Chief Complaints & Diagnosis | |
| Local PiP Self-View) | | CHART | Quick Chips (+GERD, +HTN...) | |
| | | * BP: 128/84 mmHg | Add Medication to Regimen | |
| CALL CONTROLS HUD: | | * HR: 76 bpm | * Napa Extend 665mg (1+0+1) | |
| [Mic] [Cam] [Share] [End Call] | | * Critical Allergies | * Seclo 20mg (1+0+0) | |
| [Expand Rx Full-Screen ?] | | * Server Grant Badge | Doctor Advice & Instructions | |
| | | | [Approve & Sign (Google 2FA)] | |
| ENCRYPTED PEER CHAT DRAWER | +----------------------+---------------------------------+
|
+---------------------------------+---------------------------------------------------------+
```

1. Mode A -- Live Video + E-Prescription Split View (video-split):

* Left Pane (w-5/12): Live encrypted WebRTC video stream of the patient, local self-view PiP, call HUD controls (Mic, Cam, Screen Share, Hangup), and an "Expand Rx Full-Screen ?" button, with encrypted chat directly below.

* Right Pane (w-7/12): Embedded [EPrescriptionPortal.jsx](file:///Users/mdniloy/Downloads/telehealth%20bangladesh/telehealth-bangladesh/frontend-src/src/component containing the Clinical Safety Chart and Rx Regimen Builder.

2. Mode B -- Live Audio + Full-Screen E-Prescription (audio-full):

* Docks a compact 52px audio bar at the top displaying an animated sound wave visualizer, call timer, mic mute toggle, and grant status.

* The E-Prescription Portal expands to 100% full-screen width below the audio bar.

3. Mode C -- Dedicated Full-Screen E-Prescription Portal (rx-fullscreen):

* Fills 100vw x 100vh for undistracted clinical prescription writing.

* The active call contracts into a floating Picture-in-Picture (PiP) Tile (bottom-16 left-6 w-72) displaying the remote video/audio feed and a one-click Dock Beside Call button.

4. Zero-Loss Draft Persistence Store:

* [usePrescriptionDraftStore.js](file:///Users/mdniloy/Downloads/telehealth%20bangladesh/telehealth-bangladesh/frontend-src/src/store/ preserves all typed complaints, diagnoses, and medications in memory across layout mode switches without resetting or page reloads.

Patient Encrypted Prescription Vault

Implemented in [PatientPrescriptionVault.jsx](file:///Users/mdniloy/Downloads/telehealth%20bangladesh/telehealth-bangladesh/frontend-src/src/componen and integrated into [PatientDashboard.jsx](file:///Users/mdniloy/Downloads/telehealth%20bangladesh/telehealth-bangladesh/frontend-src/src/components/Pati

* Real-Time Security Badges: [SECURE] SECURE (Active/Ready), [WARN] LOCKED (Threat lockdown), and ? QUARANTINED (Cryptographic hash mismatch).

* On-Chain Blockchain Badges: Displays verified Fabric anchor status, TxID, and SHA-256 digest verified directly against the chaincode ledger.

* Decrypted Stream Delivery: Streams decrypted %PDF binary files directly to the patient's device with zero unencrypted cache on disk.

* Embedded Dual-Mode Recovery Modal: Handles Google Authenticator verification and 5-minute single-use OTP challenge entry.

Google Authenticator 2FA Pairing Modal

Implemented in [GoogleAuthenticatorSetupModal.jsx](file:///Users/mdniloy/Downloads/telehealth%20bangladesh/telehealth-bangladesh/frontend-src/src/co and integrated into [SecurityCenter.jsx](file:///Users/mdniloy/Downloads/telehealth%20bangladesh/telehealth-bangladesh/frontend-src/src/components/Securit

* Generates live pairing QR codes via POST /api/auth/mfa/setup.

* Displays manual Base32 key with one-click copy.

* Displays 8 emergency backup recovery codes (TB-XXXX-XXXX).

* Verifies rotating 6-digit TOTP code before activating 2FA.

7. Verification & Acceptance Test Matrix

Security Unit Acceptance Suite ('test-security-suite.ts')

Executed via node --experimental-strip-types telemedicine/backend/src/test-security-suite.ts:

Test #	Acceptance Test Case	Result
01	Doctor cannot access patient data after consultation ends (Revocation Enforced)	PASSED
02	Patient cannot download another patient's prescription (Identity Verification)	PASSED
03	PDF ciphertext cannot be read without DEK unwrapping (AES-256-GCM Envelope Protection)	PASSED
04	Modifying encrypted bytes triggers GCM auth tag failure (Tamper Detection)	PASSED
05	Blockchain hash mismatch quarantines document and halts delivery	PASSED
06	Suspicious download/authentication bursts automatically lock access	PASSED
07	Security notifications dispatched with zero exposed PHI/clinical details	PASSED
08	6-digit OTP enforces single-use, 5-minute expiry, and max retry boundaries	PASSED
09	Valid OTP is strictly rejected when document is quarantined for integrity failure	PASSED
10	Transactional retry and error containment safely recover from subsystem errors	PASSED
11	Google Authenticator RFC 6238 TOTP generates & verifies valid 6-digit token	PASSED
12	Invalid or forged Google Authenticator token strictly rejected	PASSED
13	Google Authenticator token replay attack within the same 30s window strictly rejected	PASSED
14	One-time emergency backup recovery code verified and invalidated immediately	PASSED
15	Doctor prescription approval enforces Google Authenticator 2FA before signing	PASSED
TOTAL	15 Security Tests Executed	100% PASSED

End-to-End Workflow Integration Suite ('test-in-process-integration.ts')

Executed via node --experimental-strip-types telemedicine/backend/src/test-in-process-integration.ts:

Step #	End-to-End Workflow Step	Result
01	Gateway health check passed & verified Google Authenticator RFC 6238	PASSED
02	Doctor Sarah authenticated with certified BMDC credentials	PASSED

03	Doctor Sarah successfully paired Google Authenticator (RFC 6238 TOTP)	PASSED
04	Doctor consultation grant verified active (Patient data unlocked)	PASSED
05	Prescription approval without Google Authenticator strictly rejected (403)	PASSED
06	Prescription approved with Google Authenticator (SHA-256 Digest Anchored to Fabric)	PASSED
07	Doctor consultation grant verified revoked post-approval (Access Terminated)	PASSED
08	Patient Niloy successfully downloaded decrypted PDF (Valid %PDF binary stream)	PASSED
09	Unauthorized patient download attempt strictly blocked (403 Forbidden)	PASSED
10	Patient Niloy enabled Google Authenticator for threat recovery	PASSED
11	Patient successfully restored document access via Google Authenticator	PASSED
12	Quarantined document strictly blocks OTP/TOTP unlock (Forensic Hold)	PASSED
TOTAL	12 Workflow Stages Executed	100% PASSED

Production Frontend Compilation

* Vite Production Bundler: npm --prefix "telehealth-bangladesh/frontend-src" run build
* Build Status: 1995 modules transformed into production assets in 1.13s with 0 errors.

8. Master File & Component Reference Index

```
telemedicine/
??? backend/
?   ??? prisma/
? ? ??? schema.prisma # 10 core entities & state machines
?   ??? src/
?   ?   ??? db/
? ? ? ??? sqlite-store.ts # SQLite persistent table schema
? ? ? ??? prisma-adapter.ts # Database queries & ID generator
?   ?   ??? modules/
?   ?   ?   ??? security/
?   ?   ?   ?   ??? encryption.service.ts                    # AES-256-GCM + KMS wrapping
? ? ? ? ??? security-lockdown.service.ts # Threat detection, locks, OTP challenges
?   ?   ?   ??? consultation/
? ? ? ? ??? consultation-access.service.ts # Consultation grant lifecycle enforcer
?   ?   ?   ??? blockchain/
? ? ? ? ??? blockchain.service.ts # Fabric chaincode client & hash verifier
?   ?   ?   ??? auth/
? ? ? ? ??? totp.service.ts # Google Authenticator RFC 6238 TOTP engine
?   ?   ?   ??? prescription/
? ? ? ??? prescription-secure.service.ts # Approval pipeline & patient download guard
? ? ? ??? pdf-renderer.service.ts # Puppeteer clinical PDF compiler
?   ?   ??? workers/
? ? ? ??? prescription.worker.ts # BullMQ async encryption worker
? ? ??? index.ts # Express API gateway (Port 5002)
? ? ??? test-security-suite.ts # 15/15 unit acceptance test suite
? ? ??? test-in-process-integration.ts # 12/12 in-process E2E test suite
?   ??? package.json
??? blockchain/
?   ??? chaincode/
?       ??? prescription_integrity.js                        # Hyperledger Fabric chaincode
??? frontend/ (Standalone Reference)
    ??? src/
        ??? store/
        ?   ??? usePrescriptionDraftStore.ts                 # Shared draft state store
        ??? components/
        ?   ??? prescription/
        ?   ?   ??? EPrescriptionPortal.tsx                  # Full-screen / in-call portal
        ?   ??? consultation/
        ?       ??? ConsultationRoom.tsx                     # Three-mode consultation room
        ??? pages/
            ??? doctor/
??? ConsultationsQueue.tsx # Queue cards with direct portal routing

telehealth-bangladesh/
??? frontend-src/src/
```

```
    ??? store/
? ??? usePrescriptionDraftStore.js # React in-memory zero-loss draft store
    ??? components/
? ??? EPrescriptionPortal.jsx # Full-Screen & docked consultation portal
? ??? ClinicalRoom.jsx # Live 3-mode consultation workspace
? ??? PatientPrescriptionVault.jsx # Patient encrypted vault & recovery modal
? ??? GoogleAuthenticatorSetupModal.jsx # 2FA pairing QR code & backup codes modal
? ??? SecurePrescriptionModal.jsx # Standalone fallback approval modal
? ??? DoctorDashboard.jsx # Doctor queue with direct portal launch
? ??? ConsultationPortal.jsx # Consultations hub with direct portal launch
? ??? PatientDashboard.jsx # Patient dashboard wired to secure vault
? ??? SecurityCenter.jsx # Security center wired to Google Authenticator
??? App.jsx # App router passing layout modes
```